

INCIDENT REPORT

MySQL Database Destruction & Ransom Extortion

Hostname: corp-win-na01shy · Private IP: 10.3.0.21 · Public IP: 20.7.151.231

Field	Description
Report ID	IR-2026-0717
Classification	Destructive database extortion with confirmed data exfiltration
Severity	CRITICAL (technical) / INFORMATIONAL (realized)
Framework	NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide
Engagement type	Controlled honeypot exercise with live threat actor and non-production data
First compromise	2026-07-16 18:47:26 UTC (initial external attacker login)
Containment	2026-07-21 22:09:00 UTC (VM isolated using Defender XDR)
Attacker dwell time	4 days, 3 hours, 22 minutes - INTENTIONAL (observation period)
Detection	Microsoft Sentinel (Analytics Rules) - 2 incidents, 34 alerts
Current status	Contained, eradicated and recovered (exercise closed)
Report date	2026-07-22
Prepared by	Ashiq Shaikh (SOC Analyst) (https://www.linkedin.com/in/ashiqshaikh)

Reader's Note: Nature of this engagement

This incident occurred on a deliberately exposed honeypot. The Windows VM and its MySQL instance were placed on the public internet on purpose, with intentional misconfigurations (permissive NSG rule, weak network root credential), in order to observe a genuine external adversary rather than simulate one. All database content was dummy data. No production system, real customer record or live credential was involved at any point.

Findings are drawn from **Microsoft Azure (Sentinel & Defender XDR)** log sources for detection and remediation. Where logs do not support a conclusion, the report explicitly states the unknown rather than inferring TTPs.

Contents

1. Executive Summary	3
1.1 Overview	3
1.2 MITRE ATT&CK TTPs (Tactics, Techniques, Procedures)	3
1.3 Ransom Note in MySQL Database (0.0135 Bitcoin)	4
2. Incident Details	4
2.1 Key Timestamps	4
2.2 Classification	4
2.3 Affected Assets	5
2.4 Detection Coverage	5
3. Impact Assessment	7
3.1 Confidentiality Impact (Confirmed Breach)	7
3.2 Availability Impact (Total Loss, Since Recovered)	7
3.3 Integrity Impact	8
3.4 Business Impact (Modeled Service Outage)	8
4. Indicators of Compromise (IOCs)	9
4.1 Ransom and Campaign Indicators	9
4.2 MySQL Attacker Infrastructure (with Confirmed Flow Volumes)	9
4.3 RDP Attacker Infrastructure (Separate Actor)	10
5. Incident Timeline (Attacker & SOC Analyst Activity)	12
6. Root Cause & Attack Vector	13
6.1 Primary Root Cause (Exposed MySQL Database with Weak Network Root Credentials)	13
6.2 Secondary Vector (RDP Exposed and Brute-Forced)	14
6.3 Attribution (Two Independent Threat Actors)	14
6.4 Investigative Assumptions (Explicitly Ruled Out Hypotheses)	14
7. Response Actions	16
7.1 Containment (Completed)	16
7.2 Eradication (Completed)	16
7.3 Recovery (Completed)	17
7.4 Outstanding Items (Recommended, Not Yet Performed)	17
8. Evidence	17
8.1 Remaining Collection Gaps	18
9. Lessons Learned & Recommendations	18
Appendix A (Open Items & Resolution Status)	19
Appendix B (Phase Mapping for NIST 800-61 Rev. 2)	19

1. Executive Summary

NIST 800-61 Rev. 2 Phase: *Preparation and Post-Incident Activity*

1.1 Overview

A deliberately exposed honeypot MySQL server was accessed by an external attacker on 2026-07-17 at 06:30 UTC. The malicious actor logged into the database's network 'root' account, enumerated its contents, copied them out, and destroyed its contents. Approximately 505 KB of data was exfiltrated to '64.89.163.179' external IP address. After data exfiltration, the attacker dropped the 'sakila', 'world', and 'shy_corp_01' databases consisting of PII dummy data (customer names, SSNs, date of birth, payment card data, credentials). After dropping the tables and schemas, the attacker replaced them with a 'RECOVER_YOUR_DATA' table demanding a Bitcoin ransom payment.

Two (2) Microsoft Sentinel analytics rules detected the intrusion as it happened, generating 34 alerts across 2 incidents in Microsoft Defender XDR. The malicious actors' behavior was observed for approximately four (4) days. On 2026-07-21 at 22:09 UTC, the VM was isolated and the deleted database contents were restored from backup.

The VM and MySQL server were intentionally misconfigured (honeypot) to attract adversary traffic and observe real attacker behavior. An Azure network security group (NSG) rule named 'danger-allow-all-inbound' exposed the MySQL (3306) and RDP (3389) ports to the public internet; and the MySQL server's network 'root' account was configured with weak credentials (root:root). Both these misconfigurations were corrected during the remediation phase of the incident response lifecycle. Notably, this honeypot exercise drew two independent attackers. The first attacker compromised the MySQL server, and the second attacker compromised the host VM over RDP.

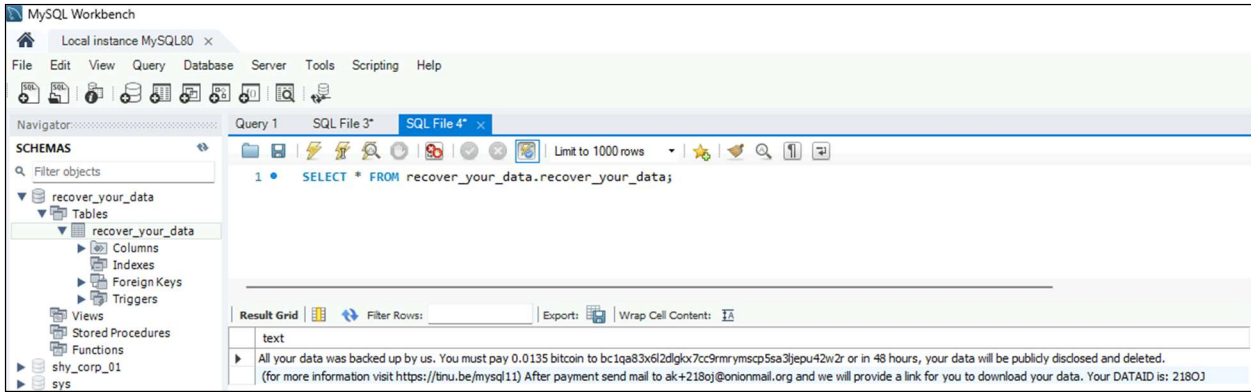
Key Findings for Attacker Behavior

1. The actor exfiltrated data before destroying the MySQL database (using DROP, ALTER queries). This is confirmed by the flow telemetry from Microsoft Sentinel's NTANetAnalytics table. This means that the ransom note's claim of "we have your data" was truthful. This is a finding that can be applied to production defense.
2. The attackers didn't break in, they logged in. Exposed services with weak credentials drew two independent adversaries within 30 hours, with no exploit, malware, or privilege escalation used by either attacker.

1.2 MITRE ATT&CK TTPs (Tactics, Techniques, Procedures)

Tactic	ID & Technique	Evidence In This Incident
Reconnaissance	T1595 - Active Scanning	7,345 unique source IPs from 97 countries scanned & probed the exposed ports during the incident timeframe.
Initial Access	T1190 - Exploit Public-Facing Application T1078 - Valid Accounts	The 'danger-allow-all-inbound' NSG rule made the MySQL (3306) and RDP (3389) ports reachable from the public internet. Successful authentication as 'root' (MySQL) and 'administrator' (RDP) using legitimate credentials from 11 unique external IP addresses.
Credential Access	T1110 - Brute Force	77 failed MySQL and 90 failed RDP authentication attempts preceding the successful logons.
Collection	T1005 - Data from Local System	'SELECT' queries used to read PII (SSN, DOB, credit cards).
Exfiltration	T1041 - Exfiltration Over C2 Channel	505 KB of data exfiltrated to external IP 64.89.163.179.
Impact	T1485 - Data Destruction T1531 - Account Access Removal T1657 - Financial Theft	Upon gaining access to the MySQL database, the malicious actor dropped 3 databases, locked out the legitimate administrator, and left a ransom note demanding bitcoin.

1.3 Ransom Note in MySQL Database (0.0135 Bitcoin)



2. Incident Details

NIST 800-61 Rev. 2 Phase: *Detection & Analysis*

2.1 Key Timestamps

Event	Timestamp (UTC)	Source
First Compromise (initial external attacker login)	2026-07-16 18:47:26	DeviceLogonEvents
First Failed MySQL Authentication	2026-07-16 23:23:19	MySQLAudit_CL (Auth logs)
Detection (first Sentinel alert)	Concurrent with attacker activity	Sentinel analytics rules (see section 2.4)
Database Destruction and Exfiltration	2026-07-17 06:30 - 06:43	MySQLAudit_CL (Query logs), NTANetAnalytics
Containment (VM isolated in Defender XDR)	2026-07-21 22:09:00	Recorded by Analyst
Total dwell time	4 days, 3 hours, 22 minutes	

Dwell Time of 4 Days (INTENTIONAL)

The custom Sentinel analytics rules generated alerts and incidents as soon as attacker behavior was detected during the four-day dwell period (see Section 2.4). This was by design, to study attacker behavior within the honeypot environment. In a production SOC, the MTTD / MTTR metrics would be measured in minutes (not hours or days).

2.2 Classification

Attribute	Assessment
Incident Type	Destructive database extortion with data theft
NOT Ransomware	The 'DeviceFileEvents' and 'DeviceRegistryEvents' tables returned negative for encryption artifacts and persistence. This validates that no encryption occurred, and no ransomware binary was executed. Instead, the attacker only exfiltrated data and wiped the MySQL server.
Severity	CRITICAL (technical) / INFORMATIONAL (realized)

Attribute	Assessment
Severity rationale	The attacker exfiltrated data and destroyed 3 databases. The technical severity of these actions is critical for a production asset. However, given the controlled context of this honeypot exercise, the severity is marked as informational.
Attack sophistication	Low. No malware, no privilege escalation, no persistence.
Threat actors	Two independent actors (see Section 6.3)

2.3 Affected Assets

Asset	Detail	Status
corp-win-na01shy	Honeypot VM hosting the MySQL instance. Internal IP 10.3.0.21, Public IP 20.7.151.231	Isolated, hardened, returned to service.
shy_corp_01	Simulated production database (customers, orders, payments, credentials tables)	Dropped by attacker; Analyst restored from backup.
sakila	Default MySQL database	Dropped by attacker; Analyst restored from backup.
world	Default MySQL database	Dropped by attacker; Analyst restored from backup.

Note on hostname truncation: The 'DeviceName' field in both Defender and Sentinel impose a character limit that renders 'corp-win-na01shy' as 'corp-win-na01sh' in certain tables. Both strings refer to the same asset. KQL queries across tables should match on (has "corp-win-na01sh") rather than an exact string to avoid missing logs.

2.4 Detection Coverage

Detection was provided by two custom Microsoft Sentinel / Defender analytics rules created specifically for this honeypot. In total, these rules generated 2 incidents and 34 alerts (medium severity) throughout the live intrusion.

Rule Name	Description	Results in Defender XDR
Ash - Successful SQL Server Logon - corp-win-na01shy	Detects successful MySQL authentication, parsed from 'MySQLAudit_CL' table data. Correlated with failed connections to suppress false positives.	Incident ID 135501 32 alerts grouped into 1 incident
Ash - Successful VM Logon - corp-win-na01shy	Detects successful VM logons (network, remote-interactive) using the 'administrator' or 'guest' accounts.	Incident ID 135693 2 alerts grouped into 1 incident

Alert Volume and Alert Suppression

The total alert count of 34 understates true attacker activity due to alert suppression rules configured for both custom analytics rules – i.e. once an alert fires, the query does not fire again for 30 minutes. The table MySQLAudit_CL (Auth logs) records 240 successful authentications across the relevant time period.

Microsoft Sentinel Analytics Rule # 1 (KQL Detection Logic) - Successful SQL Server Logon

```
// Ash - Successful SQL Server Logon - corp-win-na01shy [Severity: Medium]
let MyDevice = "corp-win-na01shy";
let FailedConnections =
    MySQLAudit_CL
    | extend RawData = replace_string(RawData, "\t", " ")
    | extend DeviceName = tostring(split(_ResourceId, "/")[1])
    | where DeviceName == MyDevice
    | where RawData has_any ("Access denied", "does not support authentication protocol",
```

```

        "Lost connection", "Aborted connection")
    | extend ConnectionId = extract(@"^S+s+(\d+)\s+Connect", 1, RawData)
    | distinct ConnectionId;
MySQLAudit_CL
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| where RawData has "Connect"
| extend ConnectionId = extract(@"^S+s+(\d+)\s+Connect", 1, RawData)
| extend ActionType =
    case(
        RawData has_any ("Access denied", "does not support authentication protocol",
            "Lost connection", "Aborted connection"), "LogonFailure",
        ConnectionId in (FailedConnections), "Ignore",
        RawData !has "@", "Ignore",
        "LogonSuccess"
    )
| where ActionType != "Ignore"
| extend Username = replace_string(tostring(split(tostring(split(RawData, "@")[0]), " ")[-1]),
    "", "")
| extend IPAddress = replace_string(tostring(split(split(RawData, "@")[1], " ")[0]), "", "")
| where ActionType == "LogonSuccess"
| project TimeGenerated, DeviceName, Username, IPAddress, ActionType, RawData
| order by TimeGenerated desc

```

TimeGenerated	DeviceName	Username	IpAddress	ActionType	RawData
> Jul 17, 2026 11:19:20 PM	corp-win-na01shy	root	64.89.163.163	LogonSuccess	2026-07-17T23:19:19.936702Z 185 Connect root@64.89.163.163 on using TCP/IP
> Jul 17, 2026 11:19:20 PM	corp-win-na01shy	root	64.89.163.163	LogonSuccess	2026-07-17T23:19:20.308557Z 186 Connect root@64.89.163.163 on using TCP/IP
> Jul 17, 2026 11:19:04 PM	corp-win-na01shy	root	64.89.163.163	LogonSuccess	2026-07-17T23:19:04.175804Z 183 Connect root@64.89.163.163 on using TCP/IP
> Jul 17, 2026 8:30:37 PM	corp-win-na01shy	root	77.90.185.30	LogonSuccess	2026-07-17T20:30:37.739959Z 70 Connect root@77.90.185.30 on using SSL/TLS
> Jul 17, 2026 6:49:55 PM	corp-win-na01shy	root	77.90.185.21	LogonSuccess	2026-07-17T18:49:55.741813Z 64 Connect root@77.90.185.21 on using SSL/TLS
> Jul 17, 2026 6:19:32 PM	corp-win-na01shy	root	213.209.159.115	LogonSuccess	2026-07-17T18:19:32.049103Z 59 Connect root@213.209.159.115 on using SSL/TLS
> Jul 17, 2026 5:48:47 PM	corp-win-na01shy	root	77.90.185.30	LogonSuccess	2026-07-17T17:48:47.193502Z 53 Connect root@77.90.185.30 on using SSL/TLS
> Jul 17, 2026 5:01:20 PM	corp-win-na01shy	root	91.217.249.32	LogonSuccess	2026-07-17T17:01:20.160765Z 48 Connect root@91.217.249.32 on using SSL/TLS
> Jul 17, 2026 5:01:16 PM	corp-win-na01shy	root	91.217.249.32	LogonSuccess	2026-07-17T17:01:16.036857Z 47 Connect root@91.217.249.32 on using SSL/TLS
> Jul 17, 2026 5:01:07 PM	corp-win-na01shy	root	91.217.249.32	LogonSuccess	2026-07-17T17:01:07.778028Z 45 Connect root@91.217.249.32 on using SSL/TLS
> Jul 17, 2026 5:01:03 PM	corp-win-na01shy	root	91.217.249.32	LogonSuccess	2026-07-17T17:01:03.621648Z 44 Connect root@91.217.249.32 on using SSL/TLS
> Jul 17, 2026 5:00:59 PM	corp-win-na01shy	root	91.217.249.32	LogonSuccess	2026-07-17T17:00:59.469902Z 43 Connect root@91.217.249.32 on using SSL/TLS

Microsoft Sentinel Analytics Rule # 2 (KQL Detection Logic) - Successful VM Logon

```

// Ash - Successful VM Logon - corp-win-na01shy [Severity: Medium]
DeviceLogonEvents
| where DeviceName has "corp-win-na01sh"
| where AccountName in~ ("administrator", "guest")
| where ActionType == "LogonSuccess"
| project TimeGenerated, RemoteIP, AccountName, DeviceName, ActionType, LogonType
| order by TimeGenerated desc

```

TimeGenerated	RemoteIP	AccountName	DeviceName	ActionType	LogonType
> Jul 17, 2026 12:45:40 AM		administrator	corp-win-na01sh	LogonSuccess	Network
> Jul 17, 2026 12:45:40 AM	102.88.21.215	administrator	corp-win-na01sh	LogonSuccess	Network
> Jul 17, 2026 12:46:45 AM	85.234.69.235	administrator	corp-win-na01sh	LogonSuccess	Network
> Jul 17, 2026 12:46:48 AM	85.234.69.235	administrator	corp-win-na01sh	LogonSuccess	Network
> Jul 17, 2026 12:46:52 AM		administrator	corp-win-na01sh	LogonSuccess	RemoteInteractive
> Jul 17, 2026 12:46:52 AM	85.234.69.235	administrator	corp-win-na01sh	LogonSuccess	RemoteInteractive
> Jul 17, 2026 12:46:52 AM	85.234.69.235	administrator	corp-win-na01sh	LogonSuccess	RemoteInteractive
> Jul 18, 2026 6:52:41 AM		administrator	corp-win-na01sh	LogonSuccess	Network
> Jul 18, 2026 6:52:41 AM	80.66.83.80	administrator	corp-win-na01sh	LogonSuccess	Network
> Jul 18, 2026 6:58:24 AM	80.66.83.80	administrator	corp-win-na01sh	LogonSuccess	Network
> Jul 18, 2026 6:58:26 AM		administrator	corp-win-na01sh	LogonSuccess	RemoteInteractive
> Jul 18, 2026 6:58:26 AM	0.0.0.0	administrator	corp-win-na01sh	LogonSuccess	RemoteInteractive

Note: Analytics Rule # 2 shown above correctly uses the 'has' operator against the truncated hostname prefix, which is why it matched despite the DeviceName character limit described in Section 2.3.

3. Impact Assessment

NIST 800-61 Rev. 2 Phase: *Detection & Analysis*

3.1 Confidentiality Impact (Confirmed Breach)

Egress flow data from the NTANetAnalytics table confirms data exfiltration by the attacker. The following flows were recorded between '64.89.163.179' and '10.3.0.21' on port 3306 (L7Protocol: mysql), prior to DB destruction.

Timestamp (UTC)	Source IP Address	Bytes server → attacker	Bytes attacker → server
2026-07-17 06:18:42	64.89.163.179	60	306
2026-07-17 06:23:42	64.89.163.179 (port 3307)	60	204
2026-07-17 06:43:58	64.89.163.179	516,672 (≈505 KB)	340,589

Why this is 'Exfiltration' rather than 'Normal Query' traffic

1. Flow Magnitude: This single flow is 516,672 bytes, which is the largest MySQL traffic flow in the entire five-day dataset, and approximately 8,611 times the median. Note: The median server-to-client volume across all 291 MySQL flows in the capture is 60 bytes.
2. Percentage (%) of Total Flow: This one flow accounts for 49.5% of all outbound MySQL data across the five-day capture period (0.99 MB total).
3. Flow Direction: 'BytesDestToSrc' measures data traveling from 10.3.0.21 (internal IP) to the attacker, which is the exfiltration direction.
4. Correlation: The traffic volume falls in the same 10-minute bucket as the DROP statements, and SELECT reads (for customers, payments, credentials, staff tables) that preceded it.
5. Attacker Tooling: The pattern observed in the query log is characteristic of mysqldump-family tooling (SELECT /*!40001 SQL_NO_CACHE */ ... LIMIT 10).

Subsequent attacker sessions show smaller traffic volumes (15 - 63 KB), consistent with ransom-note re-planting and verification rather than further bulk theft.

Re-Validating Attacker Behavior From Network Traffic Logs (NTANetAnalytics)

The attacker's claim to hold a copy of the data was truthful. An egress volume of ≈505 KB is consistent with a full dump of the observed schema for three tables (sakila, world, shy_corp_01). The most important finding of this exercise is that the attacker genuinely exfiltrates data before destroying it, rather than bluffing about possession.

3.2 Availability Impact (Total Loss, Since Recovered)

The attacker dropped three databases (shy_corp_01, sakila, world) on 2026-07-17 06:32 UTC. All three databases were restored from last good backup during remediation actions performed by the analyst (see Section 7.3).

Permanent Data-Loss Window

The backup is dated at 2026-07-15, whereas the destruction occurred on 2026-07-17 06:32 UTC. As such, any transactions written in that two-day gap are permanently lost and not recoverable from any source in evidence.

3.3 Integrity Impact

The attacker used the network root account ('root'@'%') at 06:32:12 to issue revoke commands (REVOKE INSERT, UPDATE, DELETE, DROP, CREATE ON *.*). The intent here is to block user permissions to prevent the real database administrator from using the network root account to respond to the security incident.

Note: The analyst restored the DB from last good backup. As such, the restored DB is not suspected of tampering.

3.4 Business Impact (Modeled Service Outage)

The realized business impact for this exercise is zero, since this honeypot was not connected to a live service. However, we can reconstruct a hypothetical outage window using historical log data, had this been a PROD event.

Outage Milestone	Timestamp (UTC)	Activity
Service degradation begins	2026-07-17 06:31:38	Attacker runs destructive queries (ALTER TABLE, DROP FOREIGN KEY). Referential integrity is broken from this point forward, and dependent queries start failing.
Total outage begins	2026-07-17 06:32:08	Attacker runs more destructive queries (DROP DATABASE). At this point, all data is gone and the service is fully unavailable.
Service restored	2026-07-21 22:09:00	Analyst isolates VM, performs remediation steps, and restores DB from last good backup.
Total impact window	4 days, 15 hours, 37 minutes (111.6 hours)	First destructive query to restoration.

Hunt 3.1 - Exfiltration Volume - The 516,627-byte outbound flow

```
// Hunt 3.1 - Exfiltration confirmation (the decisive query)
NTANetAnalytics
| where DestIp == "10.3.0.21" and DestPort == 3306
| where TimeGenerated between (datetime(2026-07-17 06:00) .. datetime(2026-07-17 07:00))
| project TimeGenerated, SrcPublicIps, Country, BytesSrcToDest, BytesDestToSrc, AclRule
| order by BytesSrcToDest desc
```

TimeGenerated	SrcPublicIps	Country	BytesSrcToDest	BytesDestToSrc	AclRule
> Jul 17, 2026 6:43:5...	64.89.163.179 107 107 1...	us	340589	516672	danger-allow-all-inbound
> Jul 17, 2026 6:18:4...	64.89.163.179 1 1 3 1 30...	us	306	60	danger-allow-all-inbound

Hunt 3.2 - Outlier Baseline - Comparison of median (60 bytes) to maximum (516,672 bytes)

```
// Hunt 3.2 - Baseline comparison proving the flow is a statistical outlier
NTANetAnalytics
| where DestIp = "10.3.0.21" and DestPort == 3306 and FlowDirection == "Inbound"
| summarize Median = percentile(BytesDestToSrc, 50),
               Max = max(BytesDestToSrc),
               Total = sum(BytesDestToSrc)
```

Median	Max	Total
> 60	516672	1204531

Hunt 3.3 - Sensitive Data Access – Column reads for PII, credit card, and credential data in MySQL database

```
// Hunt 3.3 - Sensitive column access immediately before destruction
let MyDevice = "corp-win-na01shy"; // set your own device name
MySQLAudit_CL
| where TimeGenerated between (datetime(2026-07-17 06:30) .. datetime(2026-07-17 06:33))
```

```

| where RawData has "Query"
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| extend ActionType = "Query"
| extend Query = split(RawData, "Query")[1]
| where Query has "SELECT" and Query has_any ("ssn", "password", "card", "date_of_birth",
"credentials")
| project TimeGenerated, Query, ActionType
| order by TimeGenerated asc

```

TimeGenerated	Query	ActionType
> Jul 17, 2026 6:31:3...	SELECT /*140001 SQL_NO_CACHE */ 'staff_id', 'first_name', 'last_name', 'address_id', 'picture', 'email', 'store_id', 'active', 'username', 'password', 'last_update' FROM 'staff' WHERE 1 LIMIT 10	Query
> Jul 17, 2026 6:31:4...	SELECT LOGFILE_GROUP_NAME, FILE_NAME, TOTAL_EXTENTS, INITIAL_SIZE, ENGINE, EXTRA FROM INFORMATION_SCHEMA.FILES WHERE FILE_TYPE = 'UNDO LOG' AND FILE_NAME IS NOT NULL...	Query
> Jul 17, 2026 6:31:4...	SELECT DISTINCT TABLESPACE_NAME, FILE_NAME, LOGFILE_GROUP_NAME, EXTENT_SIZE, INITIAL_SIZE, ENGINE FROM INFORMATION_SCHEMA.FILES WHERE FILE_TYPE = 'DATAFILE' AND TABLE...	Query
> Jul 17, 2026 6:31:4...	select column_name, extra, generation_expression, data_type from information_schema.columns where table_schema=database() and table_name='credentials' order by ordinal_position	Query
> Jul 17, 2026 6:31:4...	SELECT /*140001 SQL_NO_CACHE */ 'cred_id', 'customer_id', 'username', 'password', 'role', 'last_login' FROM 'credentials' WHERE 1 LIMIT 10	Query
> Jul 17, 2026 6:31:4...	SELECT engine, table_type FROM INFORMATION_SCHEMA.TABLES WHERE table_schema = DATABASE() AND table_name = 'credentials'	Query
> Jul 17, 2026 6:31:4...	SELECT table_name FROM INFORMATION_SCHEMA.TABLES WHERE table_schema = DATABASE() AND table_name = 'credentials'	Query
> Jul 17, 2026 6:31:4...	SELECT engine, table_type FROM INFORMATION_SCHEMA.TABLES WHERE table_schema = DATABASE() AND table_name = 'credentials'	Query
> Jul 17, 2026 6:31:4...	SELECT * FROM credentials LIMIT 10	Query
> Jul 17, 2026 6:31:4...	SELECT /*140001 SQL_NO_CACHE */ 'customer_id', 'first_name', 'last_name', 'email', 'phone', 'street', 'city', 'state', 'zip', 'date_of_birth', 'ssn', 'created_at' FROM 'customers' WHERE 1 LIMIT 10	Query
> Jul 17, 2026 6:31:5...	SELECT /*140001 SQL_NO_CACHE */ 'payment_id', 'order_id', 'card_brand', 'card_masked', 'card_last4', 'exp_month', 'exp_year' FROM 'payments' WHERE 1 LIMIT 10	Query
> Jul 17, 2026 6:31:5...	SELECT TABLE_NAME, COLUMN_NAME, CONSTRAINT_NAME, REFERENCED_TABLE_NAME, REFERENCED_COLUMN_NAME FROM information_schema.KEY_COLUMN_USAGE WHERE TABLE_SCHE...	Query

4. Indicators of Compromise (IOCs)

NIST 800-61 Rev. 2 Phase: *Detection & Analysis*

All indicators below were recovered directly from the supplied evidence (i.e. Sentinel & Defender XDR Tables).

4.1 Ransom and Campaign Indicators

Type	Value	Source table
BTC address	bc1qa83x6l2dlgkx7cc9rmrymscp5sa3ljepu42w2r	MySQLAudit_CL (Query logs)
Contact email	ak+2180j@onionmail.org	MySQLAudit_CL (Query logs)
Reference URL	hxxps://tinu[.]be/mysql11	MySQLAudit_CL (Query logs)
DATAID	2180J	MySQLAudit_CL (Query logs)
Ransom demand	0.0135 BTC → 0.0133 BTC → 0.0129 BTC (decreasing over time)	MySQLAudit_CL (Query logs)
DB artifact	Database and table named RECOVER_YOUR_DATA	MySQLAudit_CL (Query logs)
DB artifact	recover_your_data.RECOVER_YOUR_DATA_info	MySQLAudit_CL (Query logs)

4.2 MySQL Attacker Infrastructure (with Confirmed Flow Volumes)

IP address	Country	Role in Incident	Bytes Exfiltrated
64.89.163.179	us	Destruction + exfiltration	516,672
77.90.185.30	gb	Persistent brute-force, repeat access	149,546 (cumulative)
91.217.249.32	de	RECOVER_YOUR_DATA_info creation	62,793
213.209.159.115	us	Brute-force + root logon	30,748
77.90.185.21	gb	Brute-force + root logon	30,730

IP address	Country	Role in Incident	Bytes Exfiltrated
64.89.163.142	us	Wave 4 ransom-note re-plant	24,711
64.89.163.163	us	Wave 2 ransom-note re-plant	21,488
64.89.163.165	us	Wave 3 ransom-note re-plant	21,428
64.89.163.154	us	Repeat access	3,316
152.32.138.230	hk	Early root logon	1,844

Recommendation: Treat the entire '64.89.163.0/24' range as attacker-controlled. Every destructive and note-planting action in this incident originated from that block.

4.3 RDP Attacker Infrastructure (Separate Actor)

IP Address	Country	Description	Total Bytes
85.234.69.235	jp	RemoteInteractive logon session; 2.94 MB transferred in a single bucket – unexplained activity (see Section 6.3)	3,156,709
102.88.21.215	ng	37 failed logons then success; 46 flows	750,207
80.66.83.80	gb	Successful network logon on 2026-07-18	174,944

Hunt 4.1 - Source IP Attribution - for both successful and unsuccessful logins

```
// Hunt 4.1 – Attacker IPs across MySQL authentication by success/failure count
let MyDevice = "corp-win-na01shy";
let MyTimeframe = todatetime("2026-07-16T18:47:26.5144361Z");
let FailedConnections =
MySQLAudit_CL
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| where RawData has "Access denied"
| extend ConnectionId = extract(@"^S+\s+(\d+)\s+Connect", 1, RawData)
| distinct ConnectionId;
MySQLAudit_CL
| where TimeGenerated > MyTimeframe
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| where RawData has "Connect"
| extend ConnectionId = extract(@"^S+\s+(\d+)\s+Connect", 1, RawData)
| extend ActionType =
    case(
        RawData has "Access denied", "LogonFailure",
        ConnectionId in (FailedConnections), "Ignore",
        "LogonSuccess"
    )
| where ActionType != "Ignore"
| extend RawData = replace_string(RawData, "\t", " ")
| extend Username = replace_string(tostring(split(tostring(split(RawData, "@")[0]), " ")[-1]), "'", "")
| extend IpAddress = replace_string(tostring(split(split(RawData, "@")[1], " ")[0]), "'", "")
| summarize Successes = countif(ActionType == "LogonSuccess"),
    Failures = countif(ActionType == "LogonFailure"),
    First = min(TimeGenerated), Last = max(TimeGenerated)
    by IpAddress, Username
| order by Successes desc
```

IpAddress	Username	Successes	Failures	First	Last
>		86	0	Jul 16, 2026 9:23:49 PM	Jul 21, 2026 6:03:08 AM
> (ip) 64.89.163.179	root	69	2	Jul 17, 2026 6:30:07 AM	Jul 17, 2026 6:32:12 AM
> (ip) 64.89.163.163	root	12	2	Jul 17, 2026 11:19:04 PM	Jul 17, 2026 11:19:26 PM
> (ip) 64.89.163.165	root	12	2	Jul 18, 2026 1:14:48 AM	Jul 18, 2026 1:15:11 AM
> (ip) 64.89.163.142	root	12	2	Jul 21, 2026 4:34:11 AM	Jul 21, 2026 4:34:37 AM
> (ip) 77.90.185.30	root	12	15	Jul 17, 2026 3:30:44 PM	Jul 21, 2026 7:21:08 AM
> (ip) 91.217.249.32	root	11	0	Jul 17, 2026 5:00:32 PM	Jul 17, 2026 5:01:20 PM
> (ip) syn-173-197-0...	root	7	1	Jul 16, 2026 11:23:19 PM	Jul 16, 2026 11:23:20 PM
>	client	5	0	Jul 18, 2026 7:23:19 AM	Jul 21, 2026 6:41:49 AM
> (ip) localhost	root	4	1	Jul 21, 2026 11:20:00 PM	Jul 21, 2026 11:33:33 PM
> (ip) 213.209.159.115	root	3	3	Jul 17, 2026 6:19:30 PM	Jul 21, 2026 2:51:09 AM
> (ip) 77.90.185.21	root	3	3	Jul 17, 2026 6:49:53 PM	Jul 21, 2026 3:48:03 AM
> (ip) 64.89.163.154	root	2	0	Jul 18, 2026 3:12:43 AM	Jul 21, 2026 5:34:52 AM
> (ip) 152.32.138.230	root	1	0	Jul 17, 2026 2:58:35 AM	Jul 17, 2026 2:58:35 AM
> (ip) 34.62.135.217		1	0	Jul 21, 2026 6:41:49 AM	Jul 21, 2026 6:41:49 AM
> (ip) 34.76.6.170	root	1	0	Jul 18, 2026 7:23:19 AM	Jul 18, 2026 7:23:19 AM
> (ip) 34.34.189.113	root	1	0	Jul 20, 2026 11:36:31 PM	Jul 20, 2026 11:36:31 PM
> (ip) 34.62.135.217	root	1	0	Jul 21, 2026 6:41:49 AM	Jul 21, 2026 6:41:49 AM
> (ip) 34.34.189.113		1	0	Jul 20, 2026 11:36:31 PM	Jul 20, 2026 11:36:31 PM
> (ip) 77.90.185.30	admin	0	15	Jul 17, 2026 3:30:45 PM	Jul 21, 2026 7:21:07 AM
> (ip) 77.90.185.30	sa	0	15	Jul 17, 2026 3:30:45 PM	Jul 21, 2026 7:21:07 AM

Hunt 4.2 - Ransom Note Extraction & Multi-Wave Activity

- Ransom artifacts collected including BTC address, contact email address, and DATAID information
- Visibility into repeat attacker visits across full incident window to replant ransom note

```
// Hunt 4.2 – Recover all ransom-note text and embedded IOCs
let MyDevice = "corp-win-na01shy";
MySQLAudit_CL
| where TimeGenerated between (datetime(2026-07-17 06:30) .. datetime(2026-07-17 06:33))
| where RawData has "Query"
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| extend ActionType = "Query"
| extend Query = split(RawData, "Query")[1]
| where Query has_all ("RECOVER_YOUR_DATA", "bitcoin")
| project TimeGenerated, Query, ActionType
| order by TimeGenerated asc
```

TimeGenerated	Query	ActionType
> Jul 17, 2026 6:31:43 AM	INSERT INTO RECOVER_YOUR_DATA (text) VALUES (All your data was backed up by us. You must pay 0.0135 bitcoin to bc1qa83v62dglx7cc9mrmymcp5sa3jepu42w2r or in 48 hours, your data will be publicly disclosed and deleted.)	Query
> Jul 17, 2026 6:31:57 AM	INSERT INTO RECOVER_YOUR_DATA (text) VALUES (All your data was backed up by us. You must pay 0.0135 bitcoin to bc1qa83v62dglx7cc9mrmymcp5sa3jepu42w2r or in 48 hours, your data will be publicly disclosed and deleted.)	Query
> Jul 17, 2026 6:32:08 AM	INSERT INTO RECOVER_YOUR_DATA (text) VALUES (All your data was backed up by us. You must pay 0.0135 bitcoin to bc1qa83v62dglx7cc9mrmymcp5sa3jepu42w2r or in 48 hours, your data will be publicly disclosed and deleted.)	Query
> Jul 17, 2026 6:32:10 AM	INSERT INTO RECOVER_YOUR_DATA (text) VALUES (All your data was backed up by us. You must pay 0.0135 bitcoin to bc1qa83v62dglx7cc9mrmymcp5sa3jepu42w2r or in 48 hours, your data will be publicly disclosed and deleted.)	Query

5. Incident Timeline (Attacker & SOC Analyst Activity)

NIST 800-61 Rev. 2 Phase: *Detection & Analysis*

All times in UTC. Source table cited for each entry.

#	Time (UTC)	Event	Source table
1	07-16 18:47:26	First external attacker login, start of dwell period	DeviceLogonEvents
2	07-16 23:23:19	First failed MySQL authentication, credential attack begins	MySQLAudit_CL (Auth logs)
3	07-16 23:23:20	First successful root MySQL logon	MySQLAudit_CL (Auth logs)
4	07-17 00:45:40	Successful RDP logon as administrator from 102.88.21.215 after 37 failures	DeviceLogonEvents
5	07-17 00:46:52	RemoteInteractive RDP logon from 85.234.69.235	DeviceLogonEvents
6	07-17 00:54–01:04	2.94 MB transferred to 85.234.69.235 over RDP, unexplained	NTANetAnalytics
7	07-17 02:58:35	root MySQL logon from 152.32.138.230	MySQLAudit_CL (Auth logs)
8	07-17 06:18:42	64.89.163.179 initial MySQL probe (306 bytes)	NTANetAnalytics
9	07-17 06:30:07	root logon from 64.89.163.179, destruction session begins	MySQLAudit_CL (Auth logs)
10	07-17 06:30:33	SHOW DATABASES, enumeration	MySQLAudit_CL (Query logs)
11	07-17 06:30:34–06:31:37	Table enumeration and SELECT sampling of PII, card and credential columns	MySQLAudit_CL (Query logs)
12	07-17 ~06:31–06:43	≈505 KB exfiltrated to 64.89.163.179	NTANetAnalytics
13	07-17 06:31:38–06:31:43	Foreign-key constraints stripped via ALTER TABLE to enable deletion	MySQLAudit_CL (Query logs)
14	07-17 06:31:43	First ransom note planted; DROP TABLE store, staff_list	MySQLAudit_CL (Query logs)
15	07-17 06:31:56–57	orders, payments, customers, credentials tables wiped from shy_corp_01 database	MySQLAudit_CL (Query logs)
16	07-17 06:32:08–09	DROP DATABASE sakila, world, shy_corp_01	MySQLAudit_CL (Query logs)
17	07-17 06:32:12	REVOKE privileges from root@'%', anti-recovery measure	MySQLAudit_CL (Query logs)
18	07-17 17:00:35–17:01:20	Return from 91.217.249.32; RECOVER_YOUR_DATA_info created	MySQLAudit_CL (Query logs)
19	07-17 22:09–22:23	Authorized internal Nessus vulnerability scan (benign)	DeviceProcessEvents
20	07-17 23:19:25	Wave 2 - ransom note re-planted, 0.0133 BTC	MySQLAudit_CL (Query logs)
21	07-18 01:15:09	Wave 3 - ransom note re-planted	MySQLAudit_CL (Query logs)
22	07-18 06:52–06:58	Successful RDP logons from 80.66.83.80	DeviceLogonEvents
23	07-21 04:34:36	Wave 4 - ransom note re-planted, 0.0129 BTC	MySQLAudit_CL (Query logs)
24	07-21 07:21:08	Last observed attacker root logon from 77.90.185.30	MySQLAudit_CL (Auth logs)
25	07-21 22:09:00	VM isolated in Microsoft Defender, analyst containment	Completed by Analyst
26	Post-isolation	Hardening performed and database restored from Dump20260715 backup	Completed by Analyst

Hunt 5.1 - Destruction Sequence - ALTER / DROP / INSERT / REVOKE chain

```
// Hunt 5.1 – Full destruction sequence
let MyDevice = "corp-win-na01shy";
MySQLAudit_CL
| where TimeGenerated between (datetime(2026-07-17 06:30) .. datetime(2026-07-17 06:33))
| where RawData has "Query"
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| extend ActionType = "Query"
| extend Query = split(RawData, "Query")[1]
| where TimeGenerated between (datetime(2026-07-17 06:30) .. datetime(2026-07-17 06:35))
| where Query has_any ("DROP", "RENAME", "CREATE", "INSERT", "REVOKE", "ALTER")
| project TimeGenerated, Query
| order by TimeGenerated asc
```

TimeGenerated	Query
> Jul 17, 2026 6:31:43 AM	ALTER TABLE 'address' DROP FOREIGN KEY 'fk_address_city'
> Jul 17, 2026 6:31:43 AM	DROP TABLE 'store'
> Jul 17, 2026 6:31:43 AM	INSERT INTO RECOVER_YOUR_DATA (text) VALUES ('All your data was backed up by us. You must pay 0.0135 bitcoin to bc1qa83x6l2dglx7cc9mymmscp5sa3ljp42w2r or in 48 hours, your data will be publicly disclosed and deleted.')
> Jul 17, 2026 6:31:43 AM	INSERT INTO RECOVER_YOUR_DATA (text) VALUES ('(for more information visit https://tinu.be/mysql11) After payment send mail to ak+218gj@onionmail.org and we will provide a link for you to download your data. Your DATAID is: 2180J')
> Jul 17, 2026 6:31:46 AM	SET SQL_QUOTE_SHOW_CREATE=1
> Jul 17, 2026 6:31:49 AM	SET SQL_QUOTE_SHOW_CREATE=1
> Jul 17, 2026 6:31:51 AM	SET SQL_QUOTE_SHOW_CREATE=1
> Jul 17, 2026 6:31:54 AM	SET SQL_QUOTE_SHOW_CREATE=1
> Jul 17, 2026 6:31:55 AM	ALTER TABLE 'payments' DROP FOREIGN KEY 'payments_ibfk_1'
> Jul 17, 2026 6:31:56 AM	DROP TABLE 'orders'
> Jul 17, 2026 6:31:56 AM	ALTER TABLE 'orders' DROP FOREIGN KEY 'orders_ibfk_1'
> Jul 17, 2026 6:31:56 AM	DROP TABLE 'customers'
> Jul 17, 2026 6:31:56 AM	DROP TABLE 'payments'
> Jul 17, 2026 6:31:56 AM	ALTER TABLE 'credentials' DROP FOREIGN KEY 'credentials_ibfk_1'
> Jul 17, 2026 6:31:57 AM	DROP TABLE 'credentials'
> Jul 17, 2026 6:31:57 AM	INSERT INTO RECOVER_YOUR_DATA (text) VALUES ('(for more information visit https://tinu.be/mysql11) After payment send mail to ak+218gj@onionmail.org and we will provide a link for you to download your data. Your DATAID is: 2180J')
> Jul 17, 2026 6:31:57 AM	CREATE TABLE IF NOT EXISTS RECOVER_YOUR_DATA (text VARCHAR(255))
> Jul 17, 2026 6:31:57 AM	INSERT INTO RECOVER_YOUR_DATA (text) VALUES ('All your data was backed up by us. You must pay 0.0135 bitcoin to bc1qa83x6l2dglx7cc9mymmscp5sa3ljp42w2r or in 48 hours, your data will be publicly disclosed and deleted.')

6. Root Cause & Attack Vector

NIST 800-61 Rev. 2 Phase: *Preparation, Detection & Analysis*

6.1 Primary Root Cause (Exposed MySQL Database with Weak Network Root Credentials)

The NTANetAnalytics table provides direct confirmation of the exposure. Every attacker flow carries the ACL rule 'danger-allow-all-inbound' and 40,263 out of 52,005 flows from the entire capture match this rule. The Azure NSG applied to the host VM permitted unrestricted access from any host on the internal network or public internet.

Related evidence:

- 291 inbound flows to port 3306 (MySQL) originated from scanners worldwide (bg, nl, ru, br, sn, iq, hk, sg and others). This means that the host was being continuously catalogued by internet-wide scanning infrastructure.
- MySQL auth requests used the wildcard host 'root'@'%', permitting network root login from any address.
- Across 317 authentication events, root succeeded from eleven different IP addresses with no preceding failures from those same IPs, while the 'admin' and 'sa' accounts failed on every attempt. This pattern is inconsistent with a cracked password and consistent with a blank, default or widely-known root credential.

Root Cause Statement

A single permissive NSG rule (**danger-allow-all-inbound**) combined with a weak MySQL root password exposed the database to the public internet. No exploit, malware or privilege escalation was observed. The attacker simply connected and authenticated.

Both conditions were placed intentionally as honeypot bait and have since been removed. The finding that matters is how little was required. The entire compromise chain, from internet scan to total database destruction, needed nothing beyond an **open port and a guessable password**.

6.2 Secondary Vector (RDP Exposed and Brute-Forced)

Port 3389 (RDP) was publicly exposed, with 397 inbound connections and 90 failed administrator logons recorded. These were followed by three successful logons from 102.88.21.215, 85.234.69.235 and 80.66.83.80. Altogether, this constitutes a genuine, separate compromise of the Windows host VM (i.e. not related to MySQL compromise).

6.3 Attribution (Two Independent Threat Actors)

Flow data (from NTANetAnalytics table) confirms that the two attack streams (MySQL vs RDP) shared no infrastructure and never touched each other's ports.

Factor	MySQL Attacker	RDP Attacker
Infrastructure	64.89.163.0/24 (us)	85.234.69.235 (jp) 102.88.21.215 (ng) 80.66.83.80 (gb)
Protocol activity	Port 3306 only; no port 3389 flows	Port 3389 only; no port 3306 flows
Objective	Automated smash-and-grab, under 2 minutes	Hands-on-keyboard, sustained presence

Neither group ever touched the other's port. No process, file or registry artifact bridges the RDP sessions to the MySQL database activity. Post-RDP telemetry shows only routine operating system and Edge browser activity, with no 'mysql.exe' client, no credential-theft tooling, and no lateral movement. The analyst's evidence-based assessment is that two opportunistic actors were independently exploiting the same misconfigured NSG and VM.

Unexplained RDP Data Transfer

The 2.94 MB transferred to '85.234.69.235' during the 00:54 - 01:04 session is not explained by anything in the evidence. It is roughly six times larger than the confirmed database exfiltration and too large for interactive screen refresh over a session of that length.

This may represent a second, distinct data theft and is the highest priority open-item pending further investigation.

6.4 Investigative Assumptions (Explicitly Ruled Out Hypotheses)

Hypothesis	Verdict	Rationale
Host-based ransomware	Ruled Out	No encryption, no malicious Run-key persistence. DeviceFileEvents returned non-malicious BitLocker entries. All 30 Run-key writes from DeviceRegistryEvents were legitimate.
Nessus activity was attacker recon	Ruled Out	Analyst performed a manual vulnerability scan using Nessus. This is not attacker behavior. The 'nessus_cmd_' prefixes in the logs confirm this.
RDP compromise enabled the DB attack	Ruled Out	The infrastructure and port activity from the RDP and MySQL DB attacks are independent of each other. No bridging artifacts were found in the collected evidence.
Malware or persistence on host	Ruled Out	Microsoft Defender (Full Scan) on host VM returned 0 threats during remediation phase. This is consistent with a MySQL DB-only attack.

Hunt 6.1 - Internet Exposure - Worldwide Scanner Traffic to Port 3306 (MySQL)

```
// Hunt 6.1 – Exposure: breadth of internet sources reaching the database port
let MyDevice = "corp-win-na01sh";
let FirstSuccessfulLogonTime = todatetime("2026-07-17T00:45:40.5587715Z");
DeviceNetworkEvents
| where TimeGenerated >= FirstSuccessfulLogonTime
| where DeviceName == MyDevice
| where LocalPort == 3306 and ActionType == "InboundConnectionAccepted"
| summarize Connections = count(), First = min(TimeGenerated) by RemoteIP
| order by Connections desc
```

RemoteIP	Connections	First
> [🔍] 77.90.185.30	2	Jul 17, 2026 3:30:43 PM
> [🔍] 64.89.163.154	2	Jul 18, 2026 3:12:43 AM
> [🔍] 213.209.159.115	2	Jul 17, 2026 6:19:30 PM
> [🔍] 77.90.185.21	2	Jul 17, 2026 6:49:53 PM
> [🔍] 220.202.112.3	1	Jul 17, 2026 4:13:30 AM
> [🔍] 34.193.119.44	1	Jul 17, 2026 4:24:01 AM
> [🔍] 64.89.163.179	1	Jul 17, 2026 6:30:06 AM
> [🔍] 45.227.254.156	1	Jul 17, 2026 3:09:33 PM
> [🔍] 147.185.132.96	1	Jul 17, 2026 9:36:36 PM
> [🔍] 10.0.0.8	1	Jul 17, 2026 4:18:36 PM
> [🔍] 64.62.156.222	1	Jul 17, 2026 4:46:22 PM
> [🔍] 91.217.249.32	1	Jul 17, 2026 5:00:32 PM
> [🔍] 20.102.92.213	1	Jul 17, 2026 5:53:55 PM
> [🔍] 66.132.172.34	1	Jul 18, 2026 3:23:31 AM
> [🔍] 45.33.14.5	1	Jul 18, 2026 3:33:38 AM
> [🔍] 64.89.163.145	1	Jul 17, 2026 7:41:16 PM
> [🔍] 147.185.132.180	1	Jul 17, 2026 9:29:19 PM
> [🔍] 69.5.169.185	1	Jul 18, 2026 5:44:08 AM

Hunt 6.2 - Credential Strength Indicator - 'root' username has the highest number of successful logins

```
// Hunt 6.2 - Usernames for successful and failed logins (weak credential test)
let MyDevice = "corp-win-na01shy";
let MyTimeframe = todatetime("2026-07-16T18:47:26.5144361Z");
let FailedConnections =
MySQLAudit_CL
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| where RawData has "Access denied"
| extend ConnectionId = extract(@"^S+\s+(\d+)\s+Connect", 1, RawData)
| distinct ConnectionId;
MySQLAudit_CL
| where TimeGenerated > MyTimeframe
| extend RawData = replace_string(RawData, "\t", " ")
| extend DeviceName = tostring(split(_ResourceId, "/")[-1])
| where DeviceName == MyDevice
| where RawData has "Connect"
| extend ConnectionId = extract(@"^S+\s+(\d+)\s+Connect", 1, RawData)
| extend ActionType =
    case(
        RawData has "Access denied", "LogonFailure",
        ConnectionId in (FailedConnections), "Ignore",
        "LogonSuccess"
    )
| where ActionType != "Ignore"
| extend RawData = replace_string(RawData, "\t", " ")
```

```

| extend Username = replace_string(tostring(split(tostring(split(RawData,"@")[0]), " ")[-1]),
| extend IPAddress = replace_string(tostring(split(split(RawData,"@")[1], " ")[0]), "'", "")
| summarize Success = countif(ActionType == "LogonSuccess"),
              Fail = countif(ActionType == "LogonFailure")
  by Username

```

Username	Success	Fail
>	88	1
> root	151	35
> admin	0	21
> sa	0	21

Hunt 6.3 - NSG Misconfiguration Scope - Flow Count for 'danger-allow-all-inbound' NSG Rule

```

// Hunt 6.3 – Quantify the permissive NSG rule
let MyDevice = "corp-win-na01sh";
let START_TIME = todatetime("2026-07-16T18:47:26.5144361Z");
let END_TIME = todatetime("2026-07-21T22:09:00.0000000Z");
NTANetAnalytics
| where TimeGenerated between (START_TIME .. END_TIME)
| where SrcIp has_any ("20.7.151.231", "10.3.0.21") or DestIp has_any ("20.7.151.231",
"10.3.0.21")
| summarize Flows = count() by AclRule
| order by Flows desc

```

AclRule	Flows
> danger-allow-all-inbound	39396
> allowvnetoutbound	5175
> allow-scanengine-inbound	5174
> allowinternetoutbound	1792
> platformrule	1630
> denyallinbound	81
> block_all_outbound	9
> allowvnetinbound	2

7. Response Actions

NIST 800-61 Rev. 2 Phase: *Containment, Eradication & Recovery*

7.1 Containment (Completed)

Action	Timestamp / status
VM isolated in Microsoft Defender	2026-07-21 22:09:00 UTC, Completed
Network security group hardened	Completed
VM removed from isolation following hardening	Completed

7.2 Eradication (Completed)

Action	Result
Full malware scan using Windows Defender	0 threats found, consistent with DB-only attack
Windows Firewall enabled (wf.msc)	Completed

Action	Result
administrator account deleted	Completed
guest account confirmed disabled	Completed
Strong username/password set on local account	Completed
MySQL logon from public internet blocked	Completed
MySQL network root credential rotated	Completed, closes the primary access path
'danger-allow-all-inbound' NSG rule deleted	Completed, external exposure removed

7.3 Recovery (Completed)

The analyst used MySQL WorkBench data import to restore the deleted database data from last good backup (C:\Users\sshyla\Documents\dumps\Dump20260715).

For credential rotation, the MySQL network 'root' account was assigned a new password, the Windows 'administrator' account was deleted, and the Windows 'guest' account was disabled.

7.4 Outstanding Items (Recommended, Not Yet Performed)

Note: External data breach notifications are not applicable given the controlled context (honeypot exercise).

Priority	Action	Rationale
P1	Investigate the 2.94 MB RDP transfer to 85.234.69.235	Highest-value pending intelligence item from this exercise. See Section 6.3.
P1	Verify integrity of restored database, including user permission configurations	Confirm that the 'RECOVER_YOUR_DATA' ransom note objects are absent, and grants such as the REVOKE issued by the attacker at 06:32:12, are correctly restored.
P2	Add confirmed IOCs to threat-intelligence blocklists	Block 64.89.163.0/24 subnet in full (on the NSG). Also block the RDP actor IPs across PROD assets (VMs, WAFs, and NSGs).
P2	Apply the two custom Microsoft Sentinel analytics rules to PROD environment to generate alerts and incidents	The two custom analytics rules were effective in generating alerts and incidents against a live adversary. As such, they have been validated in the honeypot and can be applied to PROD.

8. Evidence

NIST 800-61 Rev. 2 Phase: *Detection & Analysis*

Artifact	Records	Contribution to Findings	Value
NTANetAnalytics	52,005	Proves data exfiltration from 516,672-byte flow logs. 'danger-allow-all-inbound' NSG rule match proves exposure.	Decisive
MySQLAudit_CL (Query logs)	790	Full MySQL DB destruction sequence (queries), all four ransom-note plants, IOC recovery	Primary
MySQLAudit_CL (Auth logs)	316	Attacker source IPs, credential evidence (username, logon type)	Primary
DeviceNetworkEvents	7,437	102 inbound flows on port 3306 (MySQL). 397 inbound flows on port 3389 (RDP).	Supporting
DeviceLogonEvents	104	90 failed and 3 successful administrator RDP logons	Supporting

Artifact	Records	Contribution to Findings	Value
DeviceProcessEvents	3,283	No attacker tooling present; Nessus scan identified and excluded	Supporting
DeviceFileEvents	4,476	No ransomware or encryption artifacts	Supporting
DeviceRegistryEvents	4,296	No malicious implants or persistence mechanisms	Supporting

8.1 Remaining Collection Gaps

1. Review MySQL binary log and 'mysql.user' at time of compromise to check if the attacker created any additional database accounts.
2. Review endpoint telemetry (VM) or session content to gather additional information about the 85.234.69.235 RDP session (see Section 6.3).

9. Lessons Learned & Recommendations

NIST 800-61 Rev. 2 Phase: *Post-Incident Activity*

Prioritized **P0** and **P1** items are time-sensitive and should be actioned on immediately.

The intentional misconfigurations in the honeypot database and host VM have been removed and remediated as outlined in Section 7. The bulk of recommendations correspond to taking what worked in the honeypot environment, and transferring it over to detect & remediate threats in PROD.

#	Pri	Recommendation	Rationale
1	P1	Create Sentinel Analytics Rule to alert on destructive queries in the MySQL database	Add coverage for the following MySQL queries: DROP DATABASE, DROP TABLE, CREATE TABLE (for ransom notes), REVOKE (against admin accounts).
2	P1	Create Sentinel Analytics Rule to alert on spikes in outbound volume per network flow logs	A rule to detect outbound traffic spikes would have alerted on the 505 KB egress (data exfiltration from MySQL database) during this incident. Can apply statistical threshold on 'BytesDestToSrc' for database flow logs.
3	P1	Apply the two custom Microsoft Sentinel analytics rules to PROD environment to generate alerts and incidents	Implement the 'Successful SQL Server Logon' and 'Successful VM Logon' Sentinel analytics rules into PROD environment. Since these rules have proven effective in the honeypot environment, we can potentially lower or remove alert suppression thresholds so that each action generates an alert.
4	P2	Create Sentinel Analytics Rule to alert on brute-force login attempts, and implement account lockout policy	90 failed RDP logons and 77 failed MySQL logons preceded the successful ones. Implementing alerting by Source IP would provide warning ahead of compromise rather than at successful logon. In our case, this rule would've flagged both threat actors before either of them authenticated successfully.
5	P2	Review NSG rules at VM, resource, and subnet levels	The honeypot drew 40,263 inbound flows from two independent adversaries within 30 hours. Due to this high traffic volume, it's important to double-check other resources within our Azure network for potential NSG misconfigurations (allow rules).
6	P2	Shorten backup RPO, verify restore point for databases, and store backups offline	Recommendation to shorten RPO by taking continuous database backups on a daily basis and storing them offline.

Appendix A (Open Items & Resolution Status)

#	Question	Status	Answer
1	Was data actually exfiltrated?	Resolved	Yes, approximately ≈505 KB of data exfiltration confirmed to 64.89.163.179 at 2026-07-17 06:43.
2	When and how was this detected, and by whom?	Resolved	Two custom Sentinel analytics rules fired during the live intrusion, which generated 34 alerts across 2 Defender XDR incidents (135501, 135693). See Section 2.4.
3	Do backups predating 07-17 06:31 exist and restore cleanly?	Resolved	Yes, databases were restored successfully (~2-day data-loss gap).
4	Are corp-win-na01sh and corp-win-na01shy the same asset?	Resolved	Yes, they're the same asset. The short form is a 'DeviceName' field character limit in Defender / Sentinel, not a separate host.
5	Was the 07-17 22:09 Nessus scan authorized?	Resolved	Yes, this was an authorized internal scan confirmed by analyst (benign).
6	Did the RDP compromise contribute to the database attack?	Resolved	No, the RDP compromise and MySQL database compromise were performed by two independent threat actors. They don't share infrastructure or port activity (TTPs).
7	Is attacker access now revoked?	Resolved	Yes, the attackers' access is revoked. The host VM was isolated on 2026-07-21 22:09 UTC. Remediation steps were performed accordingly (rotated credentials, deleted overly permissive NSG rule).
8	What explains the 2.94 MB RDP transfer to 85.234.69.235?	Pending (open-item)	This could be a signifier of possible second data exfiltration of database-unrelated content from the host VM. Pending further investigation (see Section 6.3 for details).

Appendix B (Phase Mapping for NIST 800-61 Rev. 2)

Lifecycle Phase	Report Sections	Assessment
Preparation	2.4 (detection coverage), 6 (root cause)	Effective: intentional misconfigurations were placed in advance, controlled exposure of network resources to public internet.
Detection & Analysis	2, 3, 4, 5, 6, 8	Effective: both custom analytics rules fired during the live intrusion, able to reconstruct full event timeline from log data.
Containment, Eradication & Recovery	7	Effective: isolate VM, rotated credentials, hardened NSG, performed remediation steps as documented in §7.
Post-Incident Activity	9, Appendix A	In Progress: identified detection gaps for PROD, pending to investigate second data exfiltration from host VM (RDP).